Note de partage communautaire

INC-2026-0302 | TLP:AMBER | 10 octobre 2026
Politique proposée pour le dossier pédagogique Helios Energy.

Objectif et périmètre

Permettre à des équipes de défense de repérer des comportements comparables, sans exposer l'organisation, les personnes ou l'enquête. Cette note définit une politique proposée pour l'exercice Helios Energy ; aucun partage externe n'a été effectué. Les indicateurs sont issus d'un corpus pédagogique : ils ne doivent pas être présentés comme des preuves d'une menace réelle ni importés automatiquement dans des listes de blocage de production.

Partage ciblé : TLP:AMBER

Un extrait peut être transmis à des CERT/CSIRT ou partenaires de confiance nommés, ayant un besoin de protection : empreintes, domaines, IP et certificats pertinents, techniques ATT&CK, chronologie utile, source, date d'observation, date de collecte et cote Admiralty. Conserver les limites des rapprochements et le caractère pédagogique. TLP:AMBER autorise la redistribution au besoin d'en connaître dans l'organisation destinataire et auprès de ses clients. Ce marquage ne constitue pas une autorisation de diffusion à toute la communauté [1].

Partage communautaire : TLP:GREEN après validation

Une version expurgée et autorisée par le responsable de l'information peut proposer à une communauté définie de défenseurs du secteur énergie les comportements génériques, techniques ATT&CK et règles Sigma, avec prérequis de journalisation, faux positifs et état des tests. Retirer identifiants de victime, noms d'hôtes et de comptes, topologie, données personnelles et détails permettant une réidentification. TLP:GREEN permet le partage dans cette communauté, sans publication sur des canaux publics [1]. Ne pas abaisser le TLP du corpus source sans autorisation.

Ce qui reste interne et pourquoi

Conserver dans un espace restreint les journaux bruts, captures non expurgées, configuration MISP, contacts, identifiants, secrets, données de collecte ou d'exfiltration et détails de remédiation : ils exposeraient les personnes, l'architecture ou les moyens de réponse. Ne pas transmettre l'export MISP ou le bundle STIX complet comme paquet communautaire. Maintenir la restriction interne du mémo SOC ; TLP:AMBER+STRICT convient à un extrait dont la diffusion doit rester limitée à l'organisation destinataire, après validation du détenteur [1].

Contrôle du paquet et traçabilité

Le RSSI ou responsable désigné valide contenu, destinataires et marquage avant diffusion. Produire un export dédié ; examiner valeurs, commentaires, descriptions, relations, noms d'organisation et métadonnées, puis vérifier son import et la cohérence des références. Appliquer le marquage dans le document et les objets exportés. Tenir un registre : version, date, destinataires, canal, autorisation et éventuelles rectifications. Utiliser un canal protégé et retirer les pièces jointes inutiles. L'acteur reste non identifié ; FIN7/Carbanak demeure une piste à faible confiance.

Diffusion publique et autorités

Aucune publication du corpus en TLP:CLEAR n'est prévue. Une synthèse générique ou des règles sans données sensibles pourraient être publiées après autorisation explicite et vérification des droits. Le TLP définit des limites de partage, pas une classification juridique, un chiffrement ou une dérogation aux obligations légales [1]. La déclaration ANSSI et, si applicable, la notification CNIL suivent leurs procédures dédiées, distinctes du partage communautaire.

[1] FIRST, Traffic Light Protocol, version 2.0 ; cas d'usage. Sources consultées le 10 octobre 2026.

Sources du projet : sujet M1-04, mémo SOC, fiches binaires, export MISP et rapport CTI. Les futurs fichiers Sigma et résultats de validation seront partagés uniquement avec leur statut réel.